Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada "Vida Sana" · Registro inicial de riesgos de seguridad de la información

Dirigido al Directorio | Elaborado por: Responsable de Seguridad de la Información | Herramienta: SimpleRisk | Confidencial

1. Resumen ejecutivo

Tras la auditoría externa que señaló debilidades en nuestra gestión de riesgos, se construyó el **primer registro formal de riesgos** de la clínica en la plataforma SimpleRisk. Se identificaron y valoraron **8 riesgos** sobre los activos críticos —historias clínicas electrónicas, datos de obras sociales y facturación— usando una matriz de Probabilidad × Impacto. El perfil actual es **elevado**: 3 riesgos Críticos y 4 Altos concentran la exposición, principalmente en **ransomware, phishing y control de acceso** a datos de pacientes. Se proponen **3 planes de acción** que, de ejecutarse, reducen todos los riesgos a nivel Medio o Bajo. Se requiere aprobación del Directorio para un presupuesto inicial de **USD 13.500**.

8	3	4	3
RIESGOS IDENTIFICADOS	CRÍTICOS	ALTOS	PLANES DE ACCIÓN

Analogía para el Directorio. Nuestra clínica es como la casa de los cuentos: afuera está **el lobo feroz** —los atacantes externos (ransomware, phishing) que, igual que con Caperucita Roja, se disfrazan de algo confiable (un correo legítimo, un proveedor) para engañar al personal y entrar. La defensa no puede ser **la casa de paja ni la de madera de los tres cerditos**: necesitamos construir **la casa de ladrillos**, es decir **capas de defensa** (defensa en profundidad) que resistan aunque el lobo sople. Cada plan de acción de este reporte agrega uno de esos ladrillos.

2. Top 5 riesgos por nivel

#	Riesgo	Categoría	Valor (P×I)	Nivel
R03	Phishing y robo de credenciales al personal	Confidencialidad	20 (5×4)	CRÍTICO
R01	Ransomware sobre las historias clínicas digitales	Disponibilidad	20 (4×5)	CRÍTICO
R02	Acceso indebido / fuga de datos de pacientes	Confidencialidad / Legal	16 (4×4)	CRÍTICO
R04	Pérdida de datos por backups no verificados	Disponibilidad / Integridad	15 (3×5)	ALTO
R05	Indisponibilidad por falla eléctrica / infraestructura	Disponibilidad	12 (3×4)	ALTO

Completan el registro: R06 incumplimiento normativo (Alto), R07 malware en red plana (Alto) y R08 robo/pérdida de equipos (Medio).

3. Estado de los planes de acción

Plan	Descripción	Mitiga	Venc.	Presup.	Estado
PA-01	Backups inmutables 3-2-1 + EDR + pruebas de restore	R01, R04	60 días	USD 8.000	Planificado
PA-02	MFA obligatorio + concientización anti-phishing	R03, R01	45 días	USD 3.500	Planificado
PA-03	Control de acceso RBAC + trazabilidad de accesos	R02	90 días	USD 2.000	En análisis

Efecto esperado: ejecutados los tres planes, ningún riesgo permanece en nivel Alto o Crítico; el registro completo desciende a Medio/Bajo (riesgo residual aceptable).

4. Recomendaciones prioritarias

1. Aprobar de inmediato PA-01 y PA-02. Ransomware y phishing son hoy nuestra mayor exposición y se refuerzan entre sí. Son la primera fila de ladrillos contra el lobo.

2. Designar un responsable de protección de datos y formalizar la política de privacidad, para cerrar el hallazgo de la auditoría y el riesgo legal (Ley 25.326 / secreto médico).

3. Reubicar y proteger la sala de servidores (datacenter). Como regla de buena práctica de infraestructura, **los centros de datos nunca deben estar al lado de cocinas ni debajo de piletas**, por el riesgo de incendio e inundación respectivamente. Sumar UPS dimensionado, grupo electrógeno y monitoreo ambiental.

4. Adoptar defensa en profundidad (los "tres cerditos" bien hechos): combinar controles técnicos, físicos y administrativos, de modo que la falla de una capa no comprometa toda la casa.